

TRIBUNAL DE CONTAS DO ESTADO DE SANTA CATARINA

CARGO 3: AUDITOR FISCAL DE CONTROLE EXTERNO

ÁREA: CIÊNCIAS DA COMPUTAÇÃO

PROVA DISCURSIVA

APLICAÇÃO: 06/03/2022

PADRÃO DE RESPOSTA DEFINITIVO

~~1) Políticas e organização da segurança da informação~~

~~1) Prover orientação da direção e apoio para a segurança da informação de acordo com os requisitos do negócio e com as leis e regulamentações relevantes.~~

~~Um conjunto de políticas de segurança da informação deve ser definido, aprovado pela direção, publicado e comunicado para os funcionários e partes externas relevantes.~~

~~As políticas de segurança da informação devem ser analisadas criticamente a intervalos planejados ou quando mudanças significativas ocorrerem, para assegurar a sua contínua pertinência, adequação e eficácia.~~

~~2) Estabelecer uma estrutura de gerenciamento, para iniciar e controlar a implementação e operação da segurança da informação dentro da organização.~~

~~Responsabilidades e papéis pela segurança da informação.~~

~~Funções conflitantes e áreas de responsabilidade devem ser segregadas para reduzir as oportunidades de modificação não autorizada ou não intencional, ou uso indevido dos ativos da organização.~~

~~3) Contatos apropriados com grupos especiais, associações profissionais ou outros fóruns especializados em segurança da informação devem ser mantidos.~~

~~Segurança da informação deve ser considerada no gerenciamento de projetos, independentemente do tipo do projeto.~~

~~2) Segurança em recursos humanos~~

~~Assegurar que funcionários e partes externas entendem as suas responsabilidades e estão em conformidade com os papéis para os quais eles foram selecionados.~~

~~1) Verificações do histórico devem ser realizadas para todos os candidatos a emprego, de acordo com a ética, regulamentações e leis relevantes, e devem ser proporcionais aos requisitos do negócio, aos riscos percebidos e à classificação das informações a serem acessadas. Assegurar que os funcionários e partes externas estão conscientes e cumprem as suas responsabilidades pela segurança da informação.~~

~~2) A Direção deve requerer aos funcionários e partes externas que pratiquem a segurança da informação de acordo com o estabelecido nas políticas e procedimentos da organização. Deve existir um processo disciplinar formal, implantado e comunicado, em relação a funcionários, professores, alunos e visitantes que tenham cometido uma violação de segurança da informação. Proteger os interesses da organização como parte do processo de mudança ou encerramento da contratação.~~

~~3) As responsabilidades e obrigações pela segurança da informação que permaneçam válidas após um encerramento ou mudança da contratação devem ser definidas, comunicadas aos funcionários ou partes externas e cumpridas.~~

~~3) Controle de acesso~~

~~1) Limitar o acesso à informação e aos recursos de processamento da informação.~~

~~Uma política de controle de acesso deve ser estabelecida, documentada e analisada criticamente, baseada nos requisitos de segurança da informação e dos negócios. Os usuários devem somente receber acesso às especificamente autorizadas a usar.~~

~~2) Assegurar acesso de usuário autorizado e prevenir acesso não autorizado a sistemas e serviços. Um processo formal de registro e cancelamento de usuário deve ser implementado para permitir atribuição de direitos de acesso.~~

~~3) Análise crítica dos direitos de acesso de usuário. Os proprietários de ativos devem analisar criticamente os direitos de acesso dos usuários, a intervalos regulares.~~

Relatório técnico do projeto de implantação de Política de Gestão de Segurança da Informação da Universidade ACME.

Analizando o documento fornecido pela instituição de ensino superior com a breve descrição do seu funcionamento e de suas características e considerando como referência norteadora das normas da família NBR 27000.

A instituição possui uma população de 19.500 pessoas circulando fisicamente e/ou virtualmente nos espaços da instituição. Sendo uma instituição de ensino, o controle de acesso muito restrito não é desejável, pois isso pode prejudicar o processo de ensino, aprendizagem e pesquisa. Por outro lado, liberdade total, sem restrição, é muito prejudicial para a segurança das informações e dos processos administrativos que todas as instituições de ensino possuem. Além do perigo de ataques de criminosos cibernéticos, a instituição pode estar exposta à violação de Lei Geral de Proteção de Dados Pessoais.

Na descrição da instituição de ensino não foi especificado o seu regime de administração, se é uma instituição particular ou pública. Para implantação de uma política de segurança da informação, requer um orçamento inicial e aportes constantes, pois será uma atividade continuada e a política deve ser avaliada e revista periodicamente, uma vez que os processos institucionais, os ataques externos e internos, e as tecnologias de defesa e ataque evoluem.

A política apresentada proposta pela instituição de ensino tem como base a utilização de ferramentas de avaliação da rede de comunicação, denominada Wagner VM, e a tecnologia VAD de gerenciamento de vulnerabilidades.

Faltou no projeto de política de gerenciamento de segurança da informação um mapeamento dos requisitos e objetivos da instituição. Por analogia com outras instituições de ensino, sugere-se pelo menos segmentações de rede, um para ensino e pesquisa e outro para o processo administrativo, como secretaria, almoxarifado, financeiro entre outros. A descrição da política apresentada pela universidade ACME foi elaborada pela equipe de tecnologia sem aparente comprometimento dos seus gestores da alta administração. Foram utilizados termos muitos técnicos que dificulta a comunicação para toda a equipe de funcionários, professores e alunos, muitos leigos no tema de segurança da informação.

Uma política de segurança da informação não se limita ao uso adequado da tecnologia, mas atribuição de responsabilidades aos atores envolvidos no ecossistema de ensino e aprendizagem. Deve-se prever os casos de atores que possuem inúmeros papéis, como uma pessoa que pode ser funcionário e aluno de determinado curso, professores que podem ser alunos de pós-graduação ou de extensão, entre outras combinações de situações. Assim, o sistema de autenticação deve ser separado do sistema de autorização. O controle de acesso aos processos e procedimentos deve ser flexível e correto, para evitar que um perfil não acesse procedimentos inválidos. Evitar que uma pessoa que seja funcionário e aluno altere sua própria nota. O registro detalhado de cada operação realizada ajuda na auditoria dos processos.

Quanto à política após aprovada pelos dirigentes da instituição, deve-se fazer um trabalho de divulgação com cada setor da universidade, associação dos professores, funcionários, grêmios de alunos, enfim, toda a comunidade da instituição. Aproveitar o conhecimento dos colaboradores para aperfeiçoar a política.

Os processos administrativos devem ser seguros e garantir o perfeito funcionamento para que não afete o andamento dos trabalhos diários. Assim, deve-se elaborar um plano permanente de treinamento dos colaboradores e elaborar termos de responsabilidade dos atos dos envolvidos nos processos.

Não houve menção alguma sobre a política de contratação de funcionários e professores, como, por exemplo, verificação do histórico da vida pregressa, que deve ser realizada para todos os candidatos ao emprego, de acordo com a ética, as regulamentações e as leis relevantes, e deve ser proporcional aos requisitos do propósito da universidade, aos riscos percebidos e à classificação das informações a serem acessadas. Assegurar que os funcionários e as partes externas estejam conscientes e cumpram as suas responsabilidades pela segurança da informação. Os responsáveis pelos recursos humanos devem requerer aos funcionários e às partes externas que pratiquem a segurança da informação, de acordo com o estabelecido nas políticas e nos procedimentos da organização para assegurar que as informações administrativas que transitam na universidade ACME sejam seguras e corretas. Deve existir um processo disciplinar formal, implantado e comunicado, em relação a funcionários, professores, alunos e visitantes que tenham cometido uma violação de segurança da informação. É fundamental proteger os interesses da organização como parte do processo de mudança ou encerramento da contratação. As responsabilidades sobre as informações não se limitam aos colaboradores contratados, mas permanecem válidas após um encerramento ou uma mudança da contratação e devem ser definidas, comunicadas aos funcionários ou partes externas e cumpridas.

Uma vez determinada a política de gerenciamento da segurança da informação, publicada, atribuídas as responsabilidades, deve-se chamar a atenção para os controles e as barreiras físicas e lógicas no acesso aos espaços disponibilizados para a comunidade acadêmica.

Deve-se limitar o acesso à informação e aos recursos de processamento da informação e aos espaços físicos da universidade. Os usuários devem somente receber acesso aos espaços e às informações especificamente autorizadas a usar. Assegurar acesso de usuário autorizado e prevenir acesso não autorizado a sistemas e serviços através de um sistema único de identificação e desenvolver autorizações, conforme a necessidade do processo. Um processo formal de registro e cancelamento de usuário deve ser implementado para permitir atribuição de direitos de acesso.

A utilização de soluções, como Wagner VM e a tecnologia VAD, deve ser acompanhada por capacitação de técnicos para atualizações, ajustes e, principalmente, análise das informações coletadas de agir mais rapidamente possível em casos de violações de algumas vulnerabilidades da política de segurança da informação. Aliada às ferramentas de monitoramento das redes de comunicação, é imperativa a adoção de solução de antivírus para o ambiente corporativo, assim como para todos os computadores pessoais, *notebooks* e celulares, que utilizam a rede da instituição.

Verificando as mudanças que a COVID-19 trouxe no ambiente de trabalho, sugere-se fortemente adoção de solução de VPN para que os colaboradores possam utilizar os sistemas administrativos e acadêmicos. Para as aulas virtuais, adotar uma plataforma de ensino que esteja hospedada em um ambiente de nuvem, lembrando que este ambiente deve ser integrado em uma solução de autenticação única. Implementação de barreiras lógicas de acesso com redes virtuais e *firewalls* é fortemente recomendada.

A quantidade de dispositivos pessoais aumentou muito e a universidade deve prever dispositivos de acesso via *wi-fi* nas redes internas e para as diferentes redes disponibilizadas. Não se deve utilizar a mesma rede para as atividades acadêmicas e administrativas.

Conclusão

O documento disponibilizado pela universidade ACME ainda deve ser trabalhada para detalhar mais os diversos aspectos envolvidos na política de gerência da segurança da informação antes de pôr em prática. Em nenhum momento foi mencionada a disponibilização de recursos financeiros, pois a implantação de uma política de gerência da segurança da informação requer muitos recursos humanos e financeiros. A família de normas da NBR 27000 apresenta um conjunto de documentos, e cada uma delas tem uma função específica, mas todas têm como grandes objetivos a criação, a manutenção, a melhoria, a revisão, o funcionamento e a análise de um sistema de gerência da segurança de informações. As normas podem ser adotadas independentemente do tamanho ou do tipo da empresa, e suas diretrizes buscam fazer com que não só as informações da organização, mas, também, os sistemas estejam seguros. E recomenda-se que a Universidade ACME estude os componentes da família de normas de definam um plano de longo prazo para sua implantação, começando com atividades que forem possíveis de serem executadas, conforme a maturidade dos dirigentes junto com a disponibilidade financeira, o mais rápido possível.

QUESITOS AVALIADOS

2.1 - Políticas e organização da segurança da informação: a) Requisitos do negócio e regulamentações relevantes; b) Responsabilidades e papéis pela segurança da informação; e c) Articulação com os atores envolvidos.

0 – não desenvolveu o aspecto ou o fez de forma incorreta;

~~1 – apresentou aspectos que constam nas normas, mas fora do solicitado;~~

~~2 – apresentou apenas um aspecto das normas;~~

~~3 – apresentou dois aspectos das normas;~~

~~4 – apresentou os três aspectos devidamente fundamentados.~~

1 – apresentou apenas um aspecto das normas;

2 – apresentou dois aspectos solicitados;

3 – apresentou três aspectos solicitados;

4 – apresentou os aspectos devidamente fundamentados acrescidos de controles constantes na norma.

2.2 - Segurança em recursos humanos: a) Política de contratação de colaboradores; b) Processos de informação e capacitação de colaboradores para a política de segurança da informação; e c) Responsabilidade e obrigações pela segurança da informação

0 – não desenvolveu o aspecto ou o fez de forma incorreta;

~~1 – apresentou aspectos que constam na norma, mas fora do solicitado;~~

~~2 – apresentou apenas um aspecto das normas;~~

~~3 – apresentou dois aspectos solicitados;~~

~~4 – apresentou os três aspectos devidamente fundamentados.~~

1 – apresentou apenas um aspecto das normas;

2 – apresentou dois aspectos solicitados;

3 – apresentou três aspectos solicitados;

4 – apresentou os aspectos devidamente fundamentados acrescidos de controles constantes na norma.

2.3 - Controle de acesso: a) Regras de acesso à informação e aos recursos institucionais; b) Política de autorizações de uso das informações institucionais; e c) Monitoramento e análise dos incidentes e violações da política de segurança da informação

0 – não desenvolveu o aspecto ou o fez de forma incorreta;

~~1 – apresentou aspectos que constam na norma, mas fora do solicitado;~~

~~2 – apresentou apenas um aspecto das normas;~~

~~3 – apresentou dois aspectos solicitados;~~

~~4 – apresentou os três aspectos devidamente fundamentados.~~

1 – apresentou apenas um aspecto das normas;

2 – apresentou dois aspectos solicitados;

3 – apresentou três aspectos solicitados;

4 – apresentou os aspectos devidamente fundamentados acrescidos de controles constantes na norma.